营销日周动态汇总与风险预警 · 自动化测试方案

- 版本：V0.1
- 日期：2026-10-25
- 适用：MVP V0.1（PC Web，演示/试点范围）
- 依据：PRD V0.2 简化版、开发规划、MVP README、现有独立测试 84 项
- 结论：现有 84 项自动化测试已经覆盖"能跑通"的主流程；本方案补齐"算得对、边界稳、权限不漏"三层，目标是把每轮回归压到 5 分钟内，用红绿灯决定能不能发布。

一句话：不是从零写测试，而是在现有 84 项上补 96 项，把"演示能跑"升级为"每次改动都敢放行"。

一、先看结论

问题	结论
现在有什么	84 项自动化测试，覆盖 12 项指标复算、6 类风险、SLA、四角色权限、脱敏、导出、20 个端到端场景和 2 个页面冒烟；本次复跑 84/84 通过，用时 53.78 秒
还缺什么	没有独立单元测试套件；边界值、接口契约、批量故障注入、安全回归不系统；没有持续集成流水线；页面只在 Edge 上测
本轮做多少	新增约 96 项：单元 36、集成 16、冒烟 8、边界 20 组、安全 16 组；加上现有 84 项，全量约 180 项
准备怎么测	pytest 写脚本；固定演示数据 + 独立复算当"标准答案"；每个用例用临时数据库；页面用 Edge 无头浏览器；提交先跑 2 分钟快速套件，每晚跑全量，发布前连续跑 3 次
合格标准	自动化 100% 通过；20 个端到端场景发布时 20/20；P0/P1 缺陷 0；越权 0；脱敏 100%；密钥泄露 0；已知高危依赖漏洞 0；连续 3 次全绿
预计耗时	新增建设约 12 人天；1 人约 2.5 周，2 人约 1.5 周；每轮快速套件不超过 2 分钟，全量不超过 5 分钟；不含性能测试
明确不做	性能/并发/压测；手机/H5；真实 CRM/ERP、钉钉/企微/邮件推送；12 个月留存；渗透测试/红队

二、测试范围：本轮到底测什么

2.1 本轮覆盖

按当前可运行的 MVP 代码，覆盖 10 个页面和它们背后的接口：

1. 登录与会话：4 个演示账号、签名 Cookie、退出、过期、停用账号。
2. 今日简报：3 条结论、6 张指标卡、风险前三、指标下钻、周报切换。
3. 风险中心：列表、筛选、详情、证据链、SLA、认领、转派、关闭、升级、误报、长期跟踪。
4. 周报复盘：本周/上周、指标对比、团队排名、每日签约、风险闭环。
5. 指标中心：12 项指标 + 5 项辅助指标、缺失值显示"—"、下钻一层。
6. 数据质量：10 个源文件、完整性、重复主键、目标覆盖、组织/责任人映射、缺源影响。
7. 预警规则：6 类风险、8 个独立条件、阈值调整、启停、只有总经理能改。

8. 消息中心：站内通知、已读/全部已读、未读数量、跨用户不可见。

9. 导出与打印：日报 Excel、风险 Excel、打印版日报、水印、脱敏、二次确认。

10. 审计日志：登录、查看、导出、认领、转派、关闭、改规则、越权尝试。

2.2 本轮不覆盖

不测什么	为什么	什么时候补
性能、并发、压测、稳定性	你已明确本轮不做性能测试；当前是单机 SQLite 演示版，没有生产容量目标	试点/生产前，另做容量评估和压测
手机、H5、平板适配	MVP 明确只做 PC Web，`/m` 路由本来就是 404	下一版产品范围确定后
真实 CRM/ERP 取数	当前用 10 个 CSV、30 天、2,083 行演示数据	试点接真实数据时
钉钉/企微/邮件真实推送	当前只有站内消息，没有外部通道	试点/生产阶段
12 条以上规则、12 个月留存、附件、复杂审批	PRD 的完整产品目标，不是本轮 MVP 交付范围	下一版
渗透测试、红队、代码审计	本方案做"自动化安全回归"，不能替代专业渗透测试	上线前单独安排
生产部署、HTTPS、备份、高可用	当前是本地演示环境	生产准备阶段

2.3 PRD 和 MVP 的差异要说清

PRD 描述的是完整产品，当前 MVP 是其中一小块。本方案按 MVP 代码范围落地，避免把"还没做的功能"误判成"测试失败"：

- PRD 的"至少 12 条规则"，本轮实际交付 6 类、8 个独立条件；测试按 6 类/8 个条件测，不把另外 4 条当缺陷。
- PRD 的 H5、真实 CRM/ERP、外部推送、12 个月留存，本轮没有交付；测试不覆盖，但在"下一版测试范围"里登记。
- PRD 的 30 天试点准确率、闭环率、4 小时认领率，需要真实试点数据才能证明；本方案只保证"计算和记录正确"，不替代试点结论。

三、测试地图：六层怎么分工

测试类型	大白话	本项目具体测什么	怎么自动化	新增项	合格标准与每轮耗时
单元测试	一颗颗螺丝对不对	日期/金额取整、脱敏、组织范围、指标公式、规则阈值、日报周报时间、CSV 字段校验	pytest 纯函数 + 内存 SQLite，不启动网页服务	36	100% 通过；核心纯函数分支覆盖 ≥85%；10 秒内
集成测试	零件装起来接得上吗	接口 + 数据库 + 批处理 + 导出 + 通知 + 审计串起来	FastAPI TestClient，临时数据库，独立复算对照	16	100% 通过；不污染演示库；90 秒内
冒烟测试	核心路径还活着吗	健康检查、登录、今日简报、风险列表/详情、周报、导出弹窗、无控制台错误、四种窗口尺寸	Edge 无头浏览器 + 接口检查	8	100% 通过；2 分钟内

测试类型	大白话	本项目具体测什么	怎么自动化	新增项	合格标准与每轮耗时
回归测试	改动有没有弄坏原来的	上述全部 + 现有 84 项 + 20 个端到端场景	一条命令跑全量；提交、夜间、发布三种触发	全量约 180	100% 通过；连续 3 次；5 分钟内
边界测试	极端输入下崩不崩	阈值刚好压线、分母为 0、缺数据、月末/年末/闰日、分页越界、超长文字、坏 CSV	参数化用例 + 合成数据	20 组约 60 个组合	100% 通过；不出现 500；30 秒内
安全测试	能不能被搞坏	未登录、越权、跨组织、脱敏、SQL 注入、XSS、Excel 公式注入、审计、密钥/依赖/静态扫描	TestClient + Edge + gitleaks + pip-audit + semgrep	16 组约 50 个组合	越权 0；脱敏 100%；密钥 0；高危漏洞 0；60 秒内

性能测试本轮不做。测试套件"跑得快"是工程效率，不是产品性能指标；本方案不设 QPS、响应时间、并发数门槛。

四、每一层具体测什么

4.1 按模块看测试重点

模块	单元测试	集成/接口	边界	安全
登录/会话	签名、过期、停用判断	401/403、退出、重新登录	无 Cookie、篡改、过期	HttpOnly、SameSite、Secure 边界
权限/脱敏	组织树、手机/邮箱打码	四角色矩阵、跨组织、导出	空组织、跨级、责任人	越权、明文扫描
取数/质检	CSV 字段、日期、数字校验	缺文件回滚、质量分、影响指标	空文件、重复主键、坏日期	路径穿越、错误信息泄露
指标	12 项公式、缺失值、取整	指标接口、下钻、导出值	分母 0、目标 0、负剩余目标	参数注入、越权下钻
风险规则	6 类阈值、分级、合并	跑批生成、24 小时合并、同日跳过	3/8/15pp、20/30%、2.5 倍、50 万/30 天	规则参数篡改、非总经理修改
风险闭环	SLA、状态机、升级	认领/转派/关闭/误报/长期跟踪	4 小时、8 小时、1/3/5/10 个工作日	跨组织操作、重复关闭
日报/周报	发布时间、周范围、对比	日报/周报接口、发布状态	月末、年末、闰日、跨年周	越权查看、导出泄露
导出/打印	金额/比率格式、水印	Excel/打印接口、空数据	无数据、1,000 条上限、特殊字符	公式注入、脱敏、二次确认绕过
通知/审计	去重、未读数	通知生成、已读、审计写入	0 条未读、跨用户、重复已读	审计不可篡改、敏感信息
前端	转义函数、格式化	页面与接口数值一致	1280/1440/1600 宽度、长文本	XSS、控制台错误、越权提示

4.2 单元测试（新增 36 项）

目标：把"算错一个数、差一天、四舍五入错一位"这类问题，在打开网页之前就抓住。

- **日期与工作日（6 项）**：月初/月末、年末/年初、闰年 2 月 29 日、跨年周、周一/周五、周末顺延；红橙黄认领时限和 3/5/10 个工作日关闭时限。

- **金额与比率（6 项）**：元转万元、1 位小数、四舍五入边界（0.05、0.15、负数）、比率 1 位小数、分母为 0 返回空值、缺失值不用 0 代替。
- **脱敏（4 项）**：11 位手机号、带国家码手机号、短号码、普通邮箱、带子域名邮箱、空值；打码后不能反推完整号码。
- **组织范围（5 项）**：总经理全公司、销售总监全公司销售条线、事业部含下级、部门含本人、无权限空集；不能通过改参数越级。
- **指标公式（7 项）**：目标完成率、签约额、回款额、线索量、转化率、商机覆盖率、客单价、营销投入产出比；同比/环比；缺失日期返回空值。
- **风险阈值（4 项）**：目标缺口 3/8/15 个百分点、下滑 20%/30%、线索 −30%/−20%、覆盖 2.5 倍、大客户 50 万元/30 天、回款 50 万元/30 天；压线算不算触发。
- **日报/周报时间（4 项）**：日报 08:30、周报本周六 09:00、上周一 09:00、周中版；计划发布时间不等于实际跑批时间。

合格标准：36 项全部通过；不连数据库、不发网络请求；10 秒内跑完；核心纯函数分支覆盖 ≥85%。

4.3 集成测试（新增 16 项，复用现有 84 项）

现有 84 项已经覆盖大部分"模块接起来"的场景，不重写，继续作为回归基线。新增 16 项补接口契约和故障路径：

1. OpenAPI 契约：规划第六节列出的接口都存在，关键字段名、类型、必填项不漂移。
2. 批处理故障注入：缺 1 个源文件、缺多个源文件、CSV 中途坏行、数据库写入失败；批次标记 failed、错误写清文件名和影响指标、业务事务回滚。
3. 批处理顺序：抽取 → 指标 → 质量 → 风险 → 日报 → 周报 → 发布 → 通知 → 升级检查；顺序错了日报风险前三会不对。
4. 同日重跑：同一天跑 3 次，指标不重复、风险不重复、通知不重复、周报不重复；`batch_runs` 有 3 条记录。
5. 规则修改生效：总经理改阈值后，下一次跑批按新阈值；历史风险不被改写；非总经理改返回 403。
6. 导出边界：无数据返回 404；超过 1,000 条截断并提示；筛选为空时表头正确；金额、比率、日期格式正确。
7. 打印边界：水印存在；手机号/邮箱打码；空数据不报错；打印页不横向溢出。
8. 通知分页/已读：未读 0、1、多页；全部已读；跨用户看不到别人的通知。
9. 审计完整性：登录、查看、导出、认领、转派、关闭、改规则、越权尝试都有记录；时间、用户、对象、结果齐全。
10. 接口与页面一致：同一指标在接口、页面、Excel 三处数值一致；同一风险状态在三处一致。
11. 会话失效：Cookie 过期/篡改/退出后，页面回登录页；接口返回 401，不返回半页数据。
12. 数据库约束：重复风险编号、重复通知、重复指标快照不能写入；外键/唯一索引生效。
13. 空库/新库：从零初始化后，登录、日报、风险、周报都能打开；不依赖手工补数据。
14. 数据质量与批次关联：质量页显示的批次、源文件、检查项与本次跑批一致。
15. 错误响应：非法日期、非法级别、非法状态、非法排序返回 400/422；不返回 500。

16. 导出文件名与内容：文件名含业务日期和类型；中文不乱码；打开不提示修复。

合格标准：16 项 + 现有 84 项全部通过；每个用例独立临时库；不修改 `data/mvp.db` 和源 CSV；90 秒内跑完新增部分。

4.4 冒烟测试（新增 8 项）

目标：每次改动后，先确认"人还能用"，再谈细节。

1. `/api/health` 返回正常，明确 `mobile_supported=false`。
2. 4 个演示账号都能登录；错误账号被拒绝；退出后回登录页。
3. 总经理首屏能看到 3 条结论、6 张指标卡、风险前三。
4. 风险中心能打开列表、筛选红色、打开详情抽屉。
5. 周报能打开本周/上周，6 张指标和团队排名可见。
6. 导出中心能打开确认框；确认后能下载；取消不下载。
7. 页面无控制台错误；无横向滚动条；关键按钮可点击。
8. 四种窗口尺寸 1280×720、1280×800、1440×900、1600×900 首屏内容完整。

合格标准：8 项全部通过；Edge 无头浏览器；2 分钟内跑完；失败必须截图并保留控制台日志。

4.5 回归测试

- **每次提交/合并请求**：跑单元 + 边界 + 安全 + 集成，不跑浏览器；目标 2 分钟内给结果。
- **每天夜间**：跑全量 180 项 + Edge 页面冒烟 + 三种安全扫描；目标 6 分钟内给结果。
- **发布前**：连续跑 3 次全量；3 次都绿才允许发布；任何一次红都停下来查。
- **回归范围**：现有 84 项不缩减；新增 96 项全部纳入；20 个端到端场景每次发布必跑。
- **失败处理**：先复现，再判断是产品缺陷还是测试问题；不允许"重跑直到绿"；偶发失败（flaky）只允许重试 1 次，且必须登记、2 天内修掉。
- **合格标准**：全量 100% 通过；连续 3 次；P0/P1 缺陷 0；P2 缺陷不超过 5 个且有临时绕行方案。

4.6 边界测试（20 组，约 60 个参数组合）

边界测试是这次补强的重点。很多"演示时刚好没事、真实数据一来就崩"的问题，都出在压线值、空值和极端日期上。

#	对象	边界值	预期
1	目标缺口	2.9/3.0/3.1、7.9/8.0/8.1、14.9/15.0/15.1 个百分点	低于 3 不触发；3 黄、8 橙、15 红；压线按"达到"处理
2	业绩下滑	19.9%/20%/20.1%、29.9%/30%/30.1%	20% 橙、30% 红；只有一段下降不触发"连续两段"
3	线索异常	周环比 −29.9%/−30%/−30.1%；转化率 −19.9%/−20%/−20.1%	−30% 触发橙；−20% 触发黄；少 0.1 个百分点不触发
4	商机覆盖	2.49/2.5/2.51 倍	小于 2.5 才触发；等于 2.5 不触发
5	大客户流失	49.9/50/50.1 万元；29/30/31 天	金额和天数同时达到才触发红色
6	订单/回款	取消 49.9/50/50.1 万元；逾期 29/30/31 天	任一条件达到即触发红色

#	对象	边界值	预期
7	分母为 0	线索 0、有效线索 0、目标 0、投放费用 0	返回空值/"—"，不崩溃、不显示 0 冒充
8	剩余目标	0、负数	覆盖率返回空值，不触发"覆盖不足"
9	缺失日期	2026-10-23（无数据）	12 项指标为空；日报/周报/质量返回 404 或明确提示
10	日期边界	10 月 31 日、12 月 31 日、2028-02-29、跨年周	周范围、月范围、同比/环比正确
11	工作日边界	周五、周六、周日、法定调休（如配置）	黄色 1 个工作日顺延；红色 4 小时不按工作日算；关闭 3/5/10 个工作日正确
12	分页越界	`page_size` 0/1/100/101/1000；`page` 0/−1	参数被限制在合法范围；不 500；不返回全表
13	非法参数	日期 2026-13-40、级别"紫色"、状态"未知"、排序字段 `drop table`	400/422；不执行、不泄露 SQL
14	文字长度	关闭原因/动作/结果 4/5 字；转派备注 1/500/501 字；认领计划空	少于 5 字拒绝；超长截断或拒绝；空值 422
15	规则参数	0、负数、布尔值、未知键、黄≥橙≥红	400；不允许保存；历史风险不变
16	坏 CSV	空文件、只有表头、重复主键、缺列、坏日期、坏数字、100 条以上错误	批次 failed；错误最多列 100 条；业务事务回滚
17	导出上限	0 条、1 条、1,000 条、1,001 条	0 条 404；1,001 条截断到 1,000 并提示；文件能打开
18	空筛选	风险列表无结果、周报无数据、通知 0 条	页面显示空状态；不白屏；不报错
19	通知边界	未读 0、1、99、100；跨用户通知 id	未读数正确；跨用户 404；全部已读不重复
20	幂等边界	同日 1/2/3 次跑批；重复点击认领/关闭	第 2、3 次不新增风险/通知；重复操作有明确提示

合格标准：20 组合部通过；恶意/极端输入不出现 500；数据库不残留半成品；30 秒内跑完。

4.7 安全测试（16 组，约 50 个参数组合）

安全测试做"自动化安全回归"，不等于专业渗透测试。重点是没有登录、越权、注入、泄密和供应链问题。

#	检查组	怎么测	合格标准
1	未登录访问	不带 Cookie 请求 11 个业务接口	全部 401，不返回业务数据
2	伪造/过期会话	改 Cookie 签名、改用户 id、过期 Cookie、退出后重放	全部 401；不降级为匿名
3	停用账号	把用户状态改为停用后再登录/访问	拒绝登录；已有会话失效
4	四角色矩阵	4 个角色 × 列表/详情/下钻/导出/转派/关闭/规则/审计	允许的 100% 成功，禁止的 100% 403/404
5	跨组织对象	部门经理直接改风险 id、指标组织 id、通知 id	403/404；不泄露对象是否存在
6	总经理专属	非总经理访问审计、规则修改、手动跑批	全部 403；审计有记录
7	脱敏	扫描 API JSON、页面 HTML、Excel、打印页、审计日志	不出现完整手机号/邮箱；打码格式统一
8	SQL 注入	在关键词、级别、状态、类型、排序、日期参数放 `' OR 1=1`、`; DROP` 等	200/400；不 500；不返回全表；不执行第二条语句
9	XSS	在认领计划、关闭原因/动作/结果、转派备注放 `<script>`、`<img onerror>`	页面按文字显示；不弹窗；控制台无脚本错误

#	检查组	怎么测	合格标准
10	Excel 公式注入	把风险标题改成 `=1+1`、`+cmd`、`-1+1`、`@SUM` 后导出	单元格按文本保存，不以 `=` 开头执行；当前已实测 `=1+1` 会被当成公式，需在试点前修
11	导出二次确认	页面确认框取消/确认；直接调用导出接口	取消不下载；直接调用按产品要求处理；当前服务端无二次确认，需确认是否接受
12	Cookie 属性	检查 Set-Cookie	HttpOnly、SameSite=Lax、8 小时、Path=/；本地 HTTP 下 Secure=false，生产必须 true
13	CSRF	跨站表单/请求改状态	SameSite=Lax 能挡大部分；当前无 CSRF Token，演示可接受，生产前必须补
14	安全响应头/错误	检查 `Cache-Control`、`X-Content-Type-Options`；触发 500	敏感页 no-store；nosniff；错误不返回堆栈、SQL、绝对路径
15	审计	登录、查看、导出、认领、转派、关闭、改规则、越权	全部有记录；含时间、用户、对象、结果；日志不含密码/密钥
16	供应链/密钥	gitleaks 扫历史和工作区；pip-audit 扫依赖；semgrep 扫危险模式；npm 无项目则跳过	密钥 0；已知高危漏洞 0；semgrep 新增 ERROR 0；已有告警逐条登记

补充说明：

- 2026-10-25 已做过一轮扫描：gitleaks 历史/工作区/文档 0 泄露；pip-audit 0 个已知漏洞；npm 没有 Node 项目，不适用；semgrep 49 条告警，已逐条判断为 47 条 SQL 误报 + 2 条测试脚本 URL 告警，未发现真实漏洞。
- 这些扫描是"基线"，不是"永久免检"。每次发布仍要重跑；新增告警必须逐条说明，不能用全局忽略一关了之。
- 演示登录没有密码、Cookie 未启用 Secure、没有 CSRF Token，这些是演示环境的已知边界，不作为本轮阻断项；生产前必须补统一登录、HTTPS、CSRF 防护。

4.8 PRD 验收指标怎么对应

PRD 门槛	本方案怎么验证	现在能不能证明
M1 日报/周报、M2 风险闭环可用	20 个端到端场景 + 集成测试	能，当前 20/20
20 个端到端场景至少 18 个通过	现有 `test_e2e_scenarios.py`	能，当前 20/20；发布按 20/20 要求
P0/P1 缺陷为 0	缺陷清单 + 发布评审	能，当前 P0/P1=0
越权访问 0	四角色矩阵 + 跨组织用例	能
手机号/邮箱脱敏 100%	API/页面/Excel/打印/审计扫描	能
12 项指标准确率 ≥99.5%	独立复算 + 10 个工作日回放	演示数据 480/480 一致；真实数据准确率要试点证明
同日 3 次跑批幂等	集成测试 + 现有 S19	能
每天 08:00 前跑完、08:30 发布	批次时间戳 + 计划发布时间	时间戳能证明；真实定时调度没有，需试点补
30 天试点精确率 ≥85%、4 小时认领 ≥95%、关闭 ≥90%	试点期数据库统计 + 人工复核	演示数据不能证明，必须试点
管理者 5 分钟看懂、人工投入 −80%	可用性测试 + 计时 + 访谈	不能自动化，需人工 UAT

这张表是"诚实边界"：自动化能证明"算得对、权限对、流程对"，不能替代真实试点数据证明"业务有效"。

五、测试数据与隔离：标准答案从哪来

环境基线：Windows 11、Python 3.15、SQLite 3.53.4、Edge 156；Linux 只跑不需要浏览器的快速任务，页面测试固定在 Windows 运行器。

1. **固定演示数据**：业务日期 2026-10-24，30 天，10 个 CSV，2,083 行；自然触发 10 条风险（红 6、橙 2、黄 2）。每次测试都从这套数据生成模板库，保证结果可重复。
2. **独立复算当标准答案**：测试代码不调用产品自己的指标函数，而是从 CSV 重新算一遍，再和接口结果比。金额误差不超过 1 元，比率误差不超过 0.1 个百分点。`data/expected_risks.csv` 只做交叉核对，不作为唯一标准答案，避免"拿产品自己的结果证明产品对"。
3. **每个用例一个临时库**：从模板库复制一份到临时目录，测试只改自己的副本；`data/mvp.db` 和源 CSV 不动。这样不会出现"上一条用例把风险关了，下一条找不到待认领"。
4. **源数据也复制**：缺文件、坏 CSV 等用例改临时目录里的副本，不碰仓库里的 10 个源文件。
5. **页面测试用独立端口**：启动临时服务，随机端口，跑完就关；截图和日志放到临时目录，失败时保留。
6. **测试数据全部是假数据**：客户、联系人、手机号、邮箱、金额都是生成的；禁止把真实客户数据放进测试库。
7. **数据版本化**：演示 CSV、期望风险清单、模板库生成脚本一起纳入版本管理；数据一改，所有期望值必须同步评审。

六、自动化怎么落地

6.1 目录建议

在现有 `tests/independent/` 下扩展，不另起一套：

- `tests/independent/unit/test_dates_money.py`：日期、工作日、金额、取整。
- `tests/independent/unit/test_privacy_scope.py`：脱敏、组织范围。
- `tests/independent/unit/test_metric_formulas.py`：指标公式、缺失值。
- `tests/independent/unit/test_rule_thresholds.py`：6 类规则、压线值。
- `tests/independent/unit/test_brief_quality.py`：发布时间、周范围、CSV 校验。
- `tests/independent/boundary/test_thresholds.py`：20 组边界。
- `tests/independent/security/test_authz_privacy.py`：登录、越权、脱敏。
- `tests/independent/security/test_injection.py`：SQL 注入、XSS、Excel 公式注入。
- `tests/independent/contract/test_openapi_contract.py`：接口契约。
- `tests/independent/integration/test_batch_failures.py`：故障注入、回滚、幂等。
- `tests/independent/test_ui_smoke.py`：现有页面冒烟，继续用。
- `tests/independent/test_e2e_scenarios.py`：现有 20 个场景，继续用。

6.2 运行命令

- 快速套件（提交前，约 2 分钟）：`.venv\Scripts\python -m pytest tests\independent\unit tests\independent\boundary tests\independent\security tests\independent\contract -q`
- 全量套件（夜间/发布，约 5 分钟）：`.venv\Scripts\python -m pytest tests\independent -q`
- 页面冒烟（Windows + Edge）：`.venv\Scripts\python -m pytest tests\independent\test_ui_smoke.py -q`
- 覆盖率：`.venv\Scripts\python -m pytest tests\independent\unit --cov=app --cov-report=term-missing -q`
- 安全扫描：`gitleaks detect --source . -v`；`pip-audit -r requirements.txt`；`semgrep --config=auto --metrics=on .`
- 注意：Windows 命令行设置 UTF-8，避免中文路径/中文注释乱码：`set PYTHONUTF8=1`。

6.3 持续集成流水线

触发	跑什么	目标时间	失败是否阻断
每次提交/合并请求	单元 + 边界 + 安全 + 契约 + 集成	2 分钟内	阻断合并
每天夜间	全量 180 项 + Edge 页面冒烟 + 三种扫描	6 分钟内	阻断次日发布
发布前	连续 3 次全量 + 截图/报告归档	15 分钟内	阻断发布
每月	依赖升级 + 全量回归 + 扫描基线复核	30 分钟内	进入技术债清单

建议分工：

- 快速任务放 Linux 容器，便宜、快；页面任务放 Windows 运行器，因为 Edge 和现有 CDP 脚本在 Windows 上验证过。
- 测试报告统一输出 JUnit XML + HTML；失败用例附截图、控制台日志、请求响应摘要。
- 安全扫描输出 SARIF，接入代码扫描页面；误报写入 `security/semgrep-baseline.md`，逐条说明原因，不做全局忽略。
- 不在流水线里使用真实客户数据、生产密钥、生产数据库；演示密钥只用于本地测试。

6.4 红灯/黄灯/绿灯规则

- **红灯（必须停）**：任何自动化失败；任何 P0/P1 缺陷；任何越权成功；任何完整手机号/邮箱泄露；任何密钥进入仓库；任何高危/严重依赖漏洞。
- **黄灯（可带条件放行）**：P2 缺陷不超过 5 个且有临时绕行方案；偶发失败已登记并在 2 天内修复；覆盖率略低于目标但有说明。
- **绿灯（可发布）**：全量 100% 通过；连续 3 次；P0/P1=0；越权 0；脱敏 100%；密钥 0；高危漏洞 0；20 个端到端场景 20/20。

七、合格标准：什么算“测完了”

项目	门槛
单元测试	36 项全部通过；核心纯函数分支覆盖 ≥85%
集成测试	新增 16 项 + 现有 84 项全部通过

项目	门槛
冒烟测试	8 项全部通过；无控制台错误；四种窗口尺寸无横向溢出
回归测试	全量约 180 项 100% 通过；连续 3 次全绿
端到端场景	发布时 20/20；最低不低于 PRD 的 18/20
边界测试	20 组全部通过；恶意/极端输入不出现 500
安全测试	越权 0；脱敏 100%；密钥 0；已知高危依赖漏洞 0；semgrep 新增 ERROR 0
缺陷	P0/P1=0；P2≤5 且有绕行方案；P3 登记不阻断
稳定性	发布跑不允许偶发失败；出现即登记并 2 天内修
性能	本轮不设门槛；套件运行时间只用于工程效率

八、预计耗时：建设多久、每轮跑多久

工作	建设人天	每轮自动耗时	说明
单元测试 36 项	3	10 秒	纯函数 + 内存库，最快
边界测试 20 组	2	20 秒	参数化，写一次跑很多组合
安全测试 16 组	3	30 秒	含注入、越权、脱敏；扫描另算 1 分钟
集成测试 16 项	1	60 秒	复用现有夹具，增量不大
冒烟测试 8 项	1	90 秒	Edge 无头，Windows 运行
流水线与报告	1.5	30 秒	快速/夜间/发布三条流水线
稳定性与文档	0.5	—	连续跑 3 次、修偶发、写说明
合计	**12 人天**	**全量约 5 分钟**	不含缺陷修复和等待时间

排期建议：

- 1 个人做：约 2.5 周（12 个工作日）。
- 2 个人并行：约 1.5 周（7–8 个工作日）。
- 第 5 个工作日应能跑通"单元 + 边界 + 快速流水线"，先拿到第一版红灯/绿灯。
- 后续维护大约占测试建设量的 10%–15%；每次需求变更同步改用例和期望值，不另起炉灶。

九、角色分工与背靠背

角色	负责	不做什么
测试工程师	写测试、定期望值、跑回归、出报告	不改业务代码；不改开发自测结论
开发工程师	修缺陷、补日志、保证接口契约	不改测试期望值；不删失败用例
产品/业务	确认范围、验收口径、试点指标	不直接改测试代码
IT/运维	提供 Windows 运行器、Edge、依赖缓存	不接触真实客户数据
项目负责人	看红灯/黄灯/绿灯，决定是否放行	不以"演示能跑"替代测试结论

继续遵守背靠背原则：测试报告和验收报告分开写，测试与验收不互相读取对方报告；测试只对"代码和 PRD"负责，不对"开发说没问题"负责。

十、风险与应对

风险	影响	应对
页面测试偶发失败	团队开始不信任红灯	固定 Edge 版本、Windows 运行器、失败截图、只允许重试 1 次并登记
测试数据漂移	期望值对不上，误报增多	演示 CSV、期望清单、模板库一起版本化；数据改动必须评审
安全扫描误报多	真问题被淹没	逐条登记基线；新增告警必须解释；不做全局忽略
只测演示数据，真实数据一来就崩	试点翻车	边界/坏数据用例 + 试点前 10 个工作日真实数据回放
测试建设拖期	影响试点	先做单元 + 边界 + 快速流水线；页面和报表后置；P2 视觉问题不阻塞
把演示安全当生产安全	上线被攻击	明确演示边界；生产前补统一登录、HTTPS、CSRF、限流、渗透测试
过度测试	成本高、跑得慢	按风险分层；不做性能/手机/未交付功能；快速套件只跑高风险

十一、交付物与下一步

本轮交付物：

1. 本方案（完整版 + 两页简版）。
2. 新增测试代码：单元 36、集成 16、冒烟 8、边界 20 组、安全 16 组。
3. 三条流水线：提交快速套件、夜间全量、发布前三连跑。
4. 测试报告模板：通过/失败、耗时、截图、缺陷清单、红灯/黄灯/绿灯结论。
5. 安全扫描基线：gitleaks、pip-audit、semgrep 的结果和误报说明。

建议下一步（5 个工作日内）：

1. 确认本方案的范围、96 项增量和 12 人天估算。
2. 确定流水线跑在哪里：GitHub Actions（Linux 快速 + Windows 页面）或本机计划任务。
3. 确认演示安全边界：无密码登录、HTTP Cookie、无 CSRF Token 是否接受；Excel 公式注入和"服务端导出二次确认"是否列为试点前必须修。
4. 先搭单元 + 边界骨架，接上快速流水线，跑出第一版红灯/绿灯。
5. 用现有 84 项做一次基线三连跑，确认没有环境性偶发失败。

附录 A：用例编号规划

前缀	类型	数量	示例
U	单元测试	36	U-01 日期跨年、U-12 手机号打码
I	集成测试	16	I-03 缺源文件回滚、I-09 审计完整性
SM	冒烟测试	8	SM-01 健康检查、SM-05 周报打开
B	边界测试	20 组	B-01 目标缺口 3.0、B-16 坏 CSV
SEC	安全测试	16 组	SEC-04 四角色矩阵、SEC-10 公式注入
E2E	端到端场景	20	S01 总经理日报、S20 发布时间

前缀	类型	数量	示例
REG	回归任务	3 条流水线	REG-PR、REG-NIGHT、REG-RELEASE

附录 B：现有基线（2026-10-25 复跑）

- 命令：`PYTHONUTF8=1 .venv/Scripts/python.exe -m pytest tests/independent -q`
- 结果：84 passed，1 warning，53.78 秒。
- 唯一 warning 是 Starlette TestClient 与 httpx 的弃用提示，不是产品缺陷。
- 现有覆盖：指标复算测试 11 项（覆盖 12 项指标）、风险复算测试 9 项（覆盖 6 类风险）、SLA/状态机 8 项、权限/审计 13 项、四角色矩阵 14 项、导出/打印 5 项、端到端 20 项、页面冒烟 2 项、P2 回归 2 项。
- 现有空白：没有独立单元测试套件；没有边界/安全/契约的独立分层；没有持续集成；页面只在 Edge 上验证；没有覆盖率门槛。

这些空白不是"失败"，是这份方案要补的下一块。现有 84 项继续保留，不推倒重来。

附录 C：测试报告一页纸模板

区块	写什么	示例
结论	红灯/黄灯/绿灯 + 一句话	绿灯：可以进入试点；无 P0/P1，20/20 端到端通过
范围	版本、环境、数据、代码提交号	MVP V0.1、Windows 11、Edge 156、2026-10-24 演示数据、提交 abc1234
通过率	分层通过数 + 总耗时	单元 36/36、集成 100/100、冒烟 8/8、边界 20/20、安全 16/16；全量 180/180，4 分 52 秒
缺陷	P0/P1/P2/P3 数量 + 是否阻断	P0=0、P1=0、P2=1（有绕行）、P3=3（登记）
安全	越权、脱敏、密钥、依赖、静态扫描	越权 0、脱敏 100%、密钥 0、高危漏洞 0、semgrep 新增 ERROR 0
未覆盖	明确写出没测什么	性能、手机/H5、真实 CRM/ERP、外部推送、12 个月留存
附件	报告、截图、日志、扫描结果	JUnit XML、HTML 报告、失败截图、SARIF、扫描基线

报告只写事实：通过了多少、失败在哪、没测什么。不用"基本可用""应该没问题"这类模糊结论。